

C O L L E G E O F C O M P U T I N G S C I E N C E S

Information Technology Department
Information Assurance and Security 1
(IAS 101)

III-BSIT-C

GROUP 10

MEMBERS:

KAELA ASHLEY NICOLE ZABAT

KRISTINE ME PERALTA

MARICRIS PANUYAS

KYERBIE ADAM BAUTISTA

JOSHUA TAEZA

SUBMITTED TO:

MR. ROBERT V. OCAMPO JR.

APRIL 22, 2026

IAS Principles Exercises

1. Who is responsible for risk management in an organization? Which community of interest usually takes the lead in information security risk management?

Risk management within an organization is a shared responsibility among the three communities of interest: information security, information technology, and management and users. These groups must collaborate to effectively identify, assess, and control risks affecting organizational assets.

However, management holds the primary responsibility because it defines the organization's risk tolerance, allocates resources, and ensures that appropriate policies are implemented. In practice, the information security community typically takes the lead in managing information security risks, as they possess the specialized knowledge required to analyze threats, vulnerabilities, and controls.

2. In risk management strategies, why must periodic review be part of the process?

Periodic review is a critical component of risk management because the threat environment, system vulnerabilities, and organizational operations are constantly evolving. Risk management is not a one-time activity but a continuous and iterative process.

Regular reviews ensure that:

- Asset inventories remain accurate and complete
- Existing controls continue to be effective
- Emerging threats and vulnerabilities are identified
- Risk mitigation strategies remain cost-effective

Without periodic reassessment, organizations risk relying on outdated controls, which may lead to increased exposure and potential losses.

3. Why do networking components need more examination from an information security perspective than from a systems development perspective?

Networking components require more rigorous examination from an information security perspective because they serve as primary access points to organizational systems and data. These components are directly exposed to both internal and external environments, making them highly susceptible to attacks.

Unlike systems development, which focuses primarily on functionality and performance, information security emphasizes the protection of data confidentiality, integrity, and availability. Since networking components facilitate data transmission and connectivity, any vulnerability within them can lead to widespread compromise across the system.

4. When devising a classification scheme for system components, is it more important that the asset identification list be comprehensive or mutually exclusive? Explain the answer.

In developing a classification scheme for system components, it is more important for the asset identification list to be comprehensive rather than mutually exclusive.

A comprehensive list ensures that all assets are identified and included in the risk management process, preventing any critical resource from being overlooked. If an asset is not identified, it cannot be protected, which introduces unmanaged risk.

While mutual exclusivity helps in organizing assets into distinct categories, it is secondary in importance. The primary objective is to ensure that every asset is accounted for, even if some overlap exists in classification.

5. Describe the mitigation strategy for controlling risk. What are the three planning approaches that offer opportunities to mitigate risk?

Mitigation is a risk control strategy that focuses on reducing the impact of a risk if it occurs, rather than eliminating the risk entirely. This approach prepares the organization to respond effectively to incidents and minimize damage.

Three key planning approaches support risk mitigation:

- Incident Response Plan (IRP). Defines the procedures to be followed during a security incident to contain and manage the situation.
- Disaster Recovery Plan (DRP). Focuses on restoring systems and operations after a disruption or disaster.
- Business Continuity Plan (BCP). Ensures that critical business functions continue during and after a major incident.

These plans collectively enable the organization to maintain operational stability despite adverse events.

IAS Situational Exercises

1. Using the data classification scheme in the discussed module, identify and classify the information in your personal computer or personal digital assistant. Based on the potential for misuse or embarrassment, what information would be confidential, sensitive but unclassified, or for public release?

Applying a standard data classification scheme, information stored in a personal computer or mobile device can be categorized as follows:

- Confidential Information.
Includes passwords, financial records, private communications, and identification details. Unauthorized disclosure of this data may result in serious harm such as identity theft or financial loss.
- Sensitive but Unclassified Information.
Includes academic files, personal photos, and browsing history. While not strictly confidential, exposure may lead to embarrassment or minor consequences.
- Public Information
Includes content intended for public sharing, such as social media posts or publicly distributed documents.

This classification is based on the potential impact of misuse, disclosure, or unauthorized access.

2.

Answer:

The situation represents a legal and regulatory risk, particularly due to non-compliance with data protection laws such as the Data Privacy Act of 2012.

The absence of policies regarding data retention, access control, and user consent, along with inadequate technical safeguards, exposes the organization to legal penalties and reputational damage.

To properly manage this risk, the University should:

- Establish and enforce comprehensive data protection policies
- Define clear rules on data retention, access, and disposal

- Implement technical safeguards such as encryption, access controls, and audit logging
- Ensure compliance with data subject rights, including access, correction, and deletion of personal data
- Ensure compliance with data subject rights, including access, correction, and deletion of personal data
- Formalize agreements with third-party service providers
- Conduct regular compliance audits and risk assessments

These actions demonstrate due care and due diligence, reducing legal liability and strengthening overall security posture.

3.

Answer:

After the initial phishing incident, the organization should not have considered the issue resolved. Instead, it should have conducted a thorough post-incident analysis and risk reassessment.

Appropriate actions include:

- Identifying the root cause of the attack
- Implementing stronger security controls such as multi-factor authentication
- Enhancing email filtering and detection mechanisms
- Conducting security awareness training for employees
- Updating policies and procedures to address similar threats

Failure to implement these measures violates the principle of continuous risk management and increases the likelihood of repeated incidents.

4.

Answer:

This situation presents a security and operational risk, particularly affecting accountability, data integrity, and confidentiality.

The practice of sharing credentials leads to:

- Loss of accountability due to lack of traceability
- Increased risk of unauthorized access

- Difficulty in identifying responsible individuals for system actions

To address this risk, the organization should:

- Enforce strict access control policies prohibiting credential sharing
- Implement individual user authentication mechanisms
- Enable logging and monitoring to track user activities
- Provide employee training on security responsibilities
- Apply disciplinary measures for policy violations

These measures ensure accountability and align with the principles of due care and due diligence.

5.

Answer:

This situation highlights a failure in maintaining continuous risk management practices. Discontinuing security audits, monitoring, and reassessment leads to outdated controls and increased vulnerability to evolving threats.

This is problematic because:

- Threats continuously evolve
- Security controls degrade over time
- Unpatched vulnerabilities can be exploited
- Warning signs go undetected without monitoring

To address this issue, the organization must:

- Reinstate regular security audits and vulnerability assessments
- Continuously monitor system logs and detect anomalies
- Apply timely software updates and patches
- Perform periodic risk reassessments
- Maintain baseline security standards for ongoing comparison

Sustaining these practices ensures that security controls remain effective and that risks are consistently managed.

References

Pangasinan State University. (2020). Study guide in Information Assurance and Security: Module 3 - Legal, ethical and professional issues in information security.

Pangasinan State University. (2020). Study guide in Information Assurance and Security: Module 4 - Principles of information security (risk management).

Whitman, M. E., & Mattord, H. J. (2018). Principles of information security (6th ed.).